

Manual de OSINT & Threat Intelligence

Guia de Pesquisa Avançada e Investigação de Ameaças

A cibersegurança não se resume a invadir sistemas fechados. Em mais de 70% dos casos, a informação necessária para comprometer um alvo já está pública. Este manual é o seu arsenal para encontrar dados ocultos na internet, analisar malwares com segurança e compreender o ecossistema global de vulnerabilidades.



Google Hacking

O Google é a maior ferramenta de reconhecimento do mundo. Usando operadores avançados, você pode filtrar bilhões de páginas para encontrar painéis de administração expostos, arquivos de configuração sensíveis e credenciais vazadas.

Operadores Essenciais:

- `site:exemplo.com` - Restringe a busca a um domínio ou subdomínio específico.
- `filetype:pdf` (ou `ext:txt`) - Busca apenas por um formato de arquivo específico (ex: `.env`, `.sql`, `.log`, `.bak`).
- `intitle:"texto"` - Busca páginas que tenham a palavra exata no título da aba do navegador.
- `inurl:"texto"` - Busca páginas que tenham a palavra exata na URL (link).
- `intext:"texto"` - Busca pela palavra exata dentro do corpo da página web.
- `cache:exemplo.com` - Mostra a última versão da página salva pelo Google (útil se a página original foi apagada ou caiu).



Manipulação de URLs e Web Recon

Se você acessa `http://site.com/assets/images/logo.png`, o que acontece se você apagar `logo.png` e acessar apenas `http://site.com/assets/images/`?

Quebra de Diretórios:

- Misconfiguração: Servidores mal configurados exibirão uma lista contendo todos os arquivos daquela pasta, incluindo backups ocultos ou documentos confidenciais.
- Path Traversal (`../`): Tentar retroceder pastas no servidor. Se uma URL for `site.com/download?file=relatorio.pdf`, alterar para `?file=../../../../../etc/passwd` pode forçar o servidor a entregar senhas do sistema Linux.

Arquivos Ocultos:

- `/robots.txt` - Arquivo feito para dizer ao Google o que não indexar. Ironicamente, é onde os desenvolvedores revelam os painéis de administração escondidos (ex: `Disallow: /admin_portal_v2/`).
- `/sitemap.xml` - O mapa completo do site. Pode revelar endpoints de APIs e páginas não linkadas no menu principal.



Threat Intelligence e Análise Estática

O site VirusTotal cruza a amostra com dezenas de motores de antivírus e bancos de dados.

Pesquisa por IoCs

- Hashes: Assinaturas digitais de arquivos (MD5, SHA-1, SHA-256). É a forma mais segura de investigar um malware sem precisar baixá-lo.
- Endereços IP e URLs: Para verificar se um domínio está distribuindo Phishing ou Ransomware.

Como ler o relatório do VirusTotal:

- Detection: Mostra quantos antivírus classificam o arquivo como malicioso.
- Details: A aba mais importante para análise técnica. Mostra a data de criação real do arquivo, e o verdadeiro formato dele.
- Relations: Mostra com quais IPs ou servidores o arquivo tenta se comunicar.
- Community: Investigadores do mundo inteiro deixam comentários sobre as amostras. Em CTFs, é extremamente comum encontrar Flags escondidas nos comentários públicos de uma Hash de malware.



O Ecossistema CVE

CVE (Common Vulnerabilities and Exposures) é o dicionário global de falhas de segurança.

Entendendo o Código:

- Formato: CVE-[Ano_da_Descoberta]-[Número_Sequencial].

O Score CVSS (Common Vulnerability Scoring System):

- Low/Medium (0.1 – 6.9): Falhas que exigem acesso físico ou condições muito difíceis.
- High (7.0 – 8.9): Falhas graves, geralmente exigem que o usuário já esteja autenticado.
- Critical (9.0 – 10.0): Risco máximo. Geralmente são falhas RCE (Remote Code Execution).

Onde pesquisar sobre CVEs:

- NVD (National Vulnerability Database): O banco de dados oficial do governo americano.
- Exploit-DB: A maior biblioteca do mundo de Exploits.
- GitHub: Pesquisar por CVE-XXXX-XXXXX PoC no GitHub geralmente retorna scripts em Python, e prova de conceito feitos por pesquisadores para explorar a falha.



Dica Complementar de OSINT

Se a informação não está no Google, ela está nestas ferramentas:

- Shodan (shodan.io): Em vez de indexar sites, o Shodan indexa portas de rede, servidores, roteadores, bancos de dados abertos e até câmeras de segurança conectadas à internet.
- Wayback Machine (archive.org): Uma máquina do tempo da internet. O alvo apagou a página? O administrador deletou um documento que vazava senhas na semana passada? O Wayback Machine tira "fotos" da internet todos os dias. Você pode voltar anos no passado e acessar endpoints extintos.
- MXToolbox / ViewDNS: Ferramentas suíças para dissecar domínios. Úteis para ver o histórico de IPs, descobrir onde o site está hospedado, e checar configurações de segurança de e-mail (SPF/DMARC) frequentemente exploradas em Engenharias Sociais.

Em auditorias ou competições, enumeração é tudo. Gaste 80% do seu tempo investigando o alvo com OSINT e coletando dados, e apenas 20% executando o ataque. A resposta para o quebra-cabeça geralmente está na observação de um detalhe específico.

